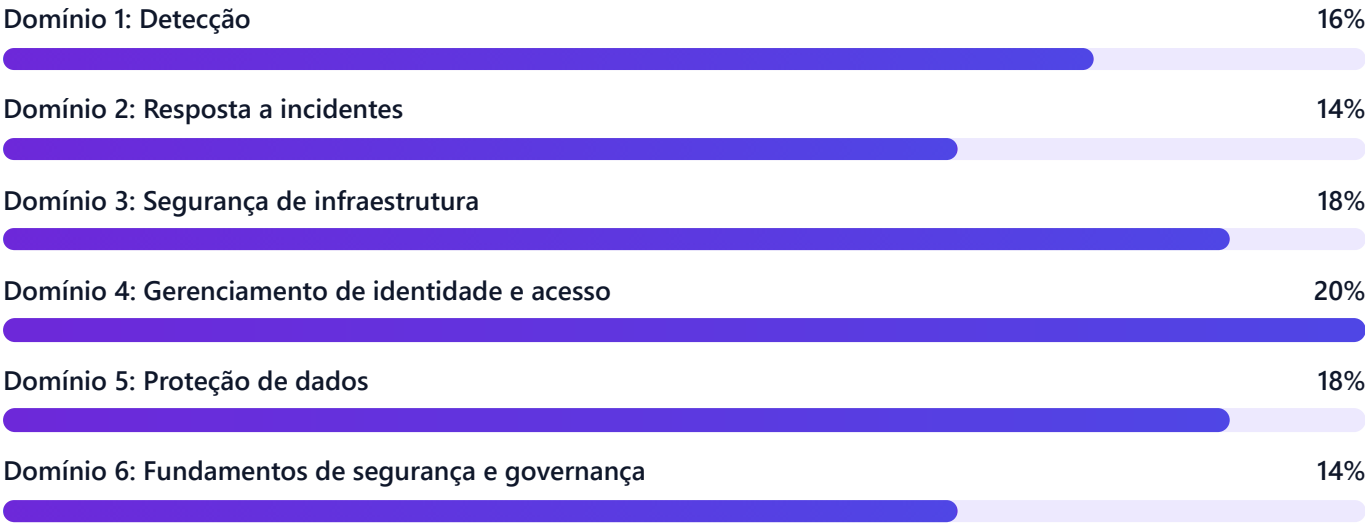
Strecht Simulados

Resumo de bolso SCS-C03

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

390	6	75%
questões no curso	provas completas	nota de corte

Como é a prova SCS-C03



Material independente de preparação, sem afiliação ou endosso de Amazon Web Services (AWS). As questões são inéditas e não reproduzem a prova real.

Pronto para o exame SCS-C03?

Treine com as 390 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Domínio 3: Segurança de infraestrutura

- Controle L7 entre serviços de várias VPCs sem appliances: VPC Lattice.
- ECS: execution role = o que o agente precisa para subir a task (imagem, logs, secrets); task role = o que o seu código chama.
- Camadas bastion, aplicação e banco: security groups referenciando security groups.
- Direct Connect + camada 2 + sem perder vazão = MACsec em conexão dedicada. Criptografia em camada 3 sobre DX = Site-to-Site VPN.
- Session Manager sem internet: endpoints de interface ssm, ssmmessages e ec2messages.
- Servidor on-premises no Systems Manager: hybrid activation + SSM Agent; o nó aparece com ID mi-.
- Verificar navegador sem atrito: Challenge (silencioso). Provar que é humano: CAPTCHA.
- Patch com atraso de aprovação, horário controlado e relatório: patch baseline + maintenance window + compliance do Patch Manager.

Domínio 4: Gerenciamento de identidade e acesso

- Reautenticar no portal: duração da sessão do Identity Center. Tempo dentro da conta: session duration do permission set.
- Ler na conta B e gravar na conta A com a mesma credencial: política de recurso (queue, bucket, topic, key policy), não AssumeRole.
- Cada usuário só vê os próprios itens do DynamoDB: dynamodb:LeadingKeys com a variável do usuário. dynamodb:Attributes limita colunas, não linhas.
- Permitir a ação só quando um serviço específico chama em seu nome: aws:CalledVia. Qualquer serviço: aws:ViaAWSService.
- Erro de "1 hour session limit" com DurationSeconds alto: é role chaining. Renove a sessão; não aumente MaxSessionDuration.
- Chave de acesso sem uso há N dias: regra iam-user-unused-credentials-check + remediação automática por SSM Automation.
- Mesma permissão em muitas identidades e necessidade de rollback: política gerenciada pelo cliente com versões. Inline só para vínculo estrito 1:1.
- Autorização dentro da sua aplicação (quem pode ver qual registro) com regras externas ao código: Verified Permissions com Cedar.

Domínio 6: Fundamentos de segurança e governança

- Gerir serviços de segurança da organização fora da conta de gerenciamento: administrador delegado.
- Impor plano de backup em todas as contas, imutável para elas: backup policy do Organizations. Vault Lock protege, não agenda.

- Inventário ou conformidade multi-conta sob demanda: advanced query do Config no agregador.
- Regra do Config personalizada sem Lambda = custom policy rule em Guard. Guard no pipeline é preventivo; Config é detetivo e pega mudanças feitas no console.
- Bloquear principais externos aos recursos da organização: RCP. Limitar o que os seus principais fazem: SCP.
- Break-glass: independente do IdP, MFA físico em cofre, alerta em cada uso e teste periódico.
- Security group padrão aplicado e mantido em várias contas: Firewall Manager com política de security group comum.
- Impedir que contas membro desliguem controles de segurança ou saiam da organização, até pelo raiz: SCP com Deny e exceção por aws:PrincipalArn.

Domínio 5: Proteção de dados

- Listener aceitando TLS 1.0 criado por IaC: defina SslPolicy explicitamente (TLS13-1-2-Res); o padrão fora do console é a 2016-08.
- Retenção regulatória que nem o raiz apaga: Object Lock Compliance; controle da chave: chave gerenciada pelo cliente.
- Snapshots EBS por tag, com retenção e cópia para outra Região, sem código: Data Lifecycle Manager. Cópia entre Regiões = chave KMS da Região de destino.
- Impedir que administradores leiam dados com criptografia transparente: chave do cliente + key policy com kms:ViaService e separação de funções.
- Segredo disponível e atualizado em outra Região para DR: replicação do Secrets Manager (réplica acompanha a rotação e pode ser promovida).
- Precisa apagar a chave da AWS na hora e trazer de volta depois? Material importado + DeleteImportedKeyMaterial + reimportação do mesmo material.
- Criptografia de EBS sem depender de quem cria: encryption by default, por conta e por Região, com chave do cliente como padrão.
- Rotação automática do KMS: simétrica com material do KMS, período configurável (padrão 365 dias), sem recriptografar.

Domínio 1: Detecção

- Flow Logs não mostram DNS da Amazon nem IMDS. Domínios consultados: Resolver query logs.
- Logs do WAF não aparecem: confira o prefixo aws-waf-logs- no nome do destino.
- Identidade IAM + integridade + prefixo = eventos de dados do CloudTrail. Falha de autenticação e lifecycle = logs de acesso do servidor.
- Log de terceiro no Security Lake: fonte personalizada em OCSF e Parquet. Quem lê: assinante.
- Formato proprietário (matrícula, ID de funcionário): custom data identifier com regex + keywords + proximidade. Allow list é para ignorar.

- Detecção gerenciada de ameaças em várias contas: GuardDuty com administrador delegado e auto-enable.
- Alerta para chamada de API específica: CloudTrail para CloudWatch Logs, metric filter, alarme e SNS (ou regra do EventBridge).
- Visibilidade de tráfego entre VPCs num ponto só, com hub de transit gateway: transit gateway flow logs.

Domínio 2: Resposta a incidentes

- Role comprometida em várias contas: SCP negando a role, quarentena por security group, logs protegidos e coleta central de evidências.
- Quem mais falou com este IP? Perfil de entidade de IP no Amazon Detective.
- Incidente com Lambda: coletar código, configuração e logs imutáveis antes de corrigir.
- Snapshot criptografado entre contas: chave do cliente (não aws/ebs), permissão no snapshot e na key policy, cópia com a chave de destino.
- Forense em instância de Auto Scaling group: primeiro desanexe ou coloque em Standby, depois isole; termination protection do EC2 não segura o Auto Scaling.
- Falso positivo validado de scanner autorizado: regra de supressão no administrador com tipo do finding + image ID ou tag. Lista de IPs confiáveis só vale para IP público.
- Logs como evidência: validação de integridade do CloudTrail e cópia com Object Lock; nunca pare o trail.
- Credencial temporária roubada: negar por aws:TokenIssueTime. Trocar instance profile ou trust policy não derruba sessões já emitidas.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Domínio 5: Proteção de dados

Uma seguradora recebe diariamente documentos de sinistros no Amazon S3 e precisa guardá-los por 10 anos de forma imutável, sem que nenhum usuário, nem o usuário raiz, consiga apagá-los ou encurtar a retenção. Depois dos primeiros 30 dias, os documentos quase nunca são lidos e uma recuperação em até 48 horas é aceitável. O diretor financeiro pede o menor custo de armazenamento possível. Qual solução atende a esses requisitos?

A. Criar um vault do Amazon S3 Glacier com uma política de Vault Lock que negue exclusões por 10 anos e copiar os documentos do bucket para o vault de forma automática depois de 30 dias
B. Habilitar S3 Object Lock em modo governance com retenção de 10 anos e usar S3 Intelligent-Tiering com as camadas opcionais de arquivamento ativadas no bucket
C. Habilitar versionamento com MFA Delete no bucket e uma regra de S3 Lifecycle que mova os objetos para S3 Standard-IA após 30 dias para reduzir custo
D. Habilitar S3 Object Lock no bucket com retenção padrão em modo compliance de 10 anos e uma regra de S3 Lifecycle que mova os objetos para S3 Glacier Deep Archive após 30 dias

Questão 2 · Domínio 5: Proteção de dados

Uma seguradora precisa proteger os volumes EBS de suas instâncias EC2 e copiar diariamente os snapshots desses volumes para uma conta de backup separada na mesma organização. Os dados devem continuar criptografados nas cópias, o controle das chaves deve ficar centralizado na equipe de segurança, com rotação automática e trilha de auditoria de cada uso. Qual solução atende melhor a esses requisitos?

A. Usar uma chave simétrica gerenciada pelo cliente, com rotação automática e key policy que concede kms:CreateGrant e kms:Decrypt à conta de backup
B. Usar uma chave assimétrica RSA do KMS nos volumes e snapshots e entregar a chave pública à conta de backup para descriptografar as cópias
C. Usar a chave aws/ebs nos volumes e compartilhar os snapshots com a conta de backup para que ela faça as cópias com a própria chave
D. Usar uma chave com material importado e rotação automática anual, com um grant permanente que libera o uso da chave à conta de backup

Questão 3 · Domínio 5: Proteção de dados

Uma organização precisa garantir que os backups de bancos de dados armazenados em um bucket Amazon S3 estejam criptografados com chaves do KMS gerenciadas pelo cliente, específicas de cada ambiente (desenvolvimento, homologação e produção). Os times não devem conseguir usar por engano a chave de outro ambiente ao executar os backups automatizados. Qual solução atende melhor a esse requisito com o menor esforço operacional?

A. Habilitar a criptografia padrão do bucket com SSE-S3 e usar SCPs do AWS Organizations para bloquear cada acesso não autorizado
B. Usar uma chave gerenciada pelo cliente por ambiente, com key policy condicionada a aws:PrincipalTag e ao contexto de criptografia do ambiente
C. Criar uma única chave gerenciada pelo cliente e usar condições na bucket policy do S3 para restringir o acesso por tags de recursos
D. Criar uma chave do cliente por conta AWS e permitir que os ambientes compartilhem a mesma chave, controlando os acessos só por políticas do IAM

Questão 4 · Domínio 2: Resposta a incidentes

Às 14h05, um ataque de SQL injection alterou saldos de clientes em uma instância do Amazon RDS for PostgreSQL de uma cooperativa de crédito, que tem backups automáticos com retenção de 14 dias. A diretoria quer o banco de volta ao estado das 14h00 o quanto antes, e o jurídico exige preservar a instância comprometida, sem alterações, para análise forense. Qual procedimento atende a esses requisitos?

A. Executar uma restauração para um ponto no tempo às 14h00 em uma instância nova, isolar a instância comprometida por security group e tirar um snapshot dela, e apontar a aplicação para a nova
B. Excluir a instância comprometida gerando um snapshot final para a perícia e restaurar uma instância nova a partir do snapshot automático da madrugada
C. Restaurar o snapshot automático mais recente sobre a instância atual, para manter o mesmo endpoint, e reaplicar os logs de transação até 14h00 pelo console do RDS, mantendo o mesmo grupo de parâmetros
D. Usar o backtrack do RDS para voltar a instância comprometida ao horário das 14h00, preservando o endpoint e evitando a criação de uma instância nova

Questão 5 · Domínio 4: Gerenciamento de identidade e acesso

Em uma seguradora, a role dos administradores de banco de dados usa uma chave KMS gerenciada pelo cliente para criar e operar instâncias RDS criptografadas em sa-east-1. A segurança descobriu que essa role também chama kms:Decrypt diretamente pelo CLI para descriptografar arquivos que outra equipe cifrou com a mesma chave. A exigência é que os DBAs só consigam usar a chave por meio do RDS nessa Região, sem afetar outros serviços que usam a chave. Qual statement da key policy, substituindo a permissão atual da role, atende a esse requisito?

A. Permitir à role dos DBAs as ações de criptografia da chave com a condição aws:CalledVia igual a rds.amazonaws.com
B. Permitir à role dos DBAs as ações de criptografia da chave com a condição kms:CallerAccount igual ao ID da conta dos bancos
C. Permitir à role dos DBAs as ações de criptografia da chave com a condição kms:ViaService igual a rds.sa-east-1.amazonaws.com
D. Permitir à role dos DBAs as ações de criptografia da chave com a condição aws:SourceVpce igual ao endpoint do RDS na VPC

Questão 6 · Domínio 4: Gerenciamento de identidade e acesso

Para padronizar, uma equipe de uma empresa de educação passou a criar as roles de execução das funções Lambda a partir de um template copiado das roles de instâncias EC2, apenas trocando as políticas de permissão. Ao criar uma função com uma dessas roles, o deploy falha com InvalidParameterValueException: The role defined for the function cannot be assumed by Lambda. O usuário do pipeline tem iam:PassRole para a role. Qual correção resolve o erro com o menor privilégio?

A. Trocar o Principal da trust policy da role de ec2.amazonaws.com para lambda.amazonaws.com com a ação sts:AssumeRole
B. Anexar à role a política gerenciada AWSLambdaBasicExecutionRole, que concede ao serviço Lambda a permissão de assumir a role de execução
C. Adicionar à função uma resource-based policy que permita lambda:InvokeFunction ao service principal lambda.amazonaws.com na conta
D. Conceder ao usuário do pipeline sts:AssumeRole na role de execução, para que ele assuma a role em nome do Lambda durante o deploy

Questão 7 · Domínio 4: Gerenciamento de identidade e acesso

A equipe de plataforma de uma fabricante de veículos publica pacotes de agentes de segurança em um bucket do S3 na conta de ferramentas. As 230 contas da organização, de todas as OUs, precisam baixar esses pacotes, e contas entram e saem da organização toda semana. A bucket policy atual lista os IDs de conta um a um e vive desatualizada. A segurança quer permitir a leitura a qualquer principal das contas da organização e a nenhum outro, sem manutenção da lista. Qual instrução na bucket policy atende a esse requisito?

A. Allow em s3:GetObject para o Principal "*" com a condição StringEquals aws:PrincipalOrgID igual ao ID da organização no recurso do bucket de pacotes
B. Allow em s3:GetObject para o Principal "*" com a condição StringEquals aws:SourceOrgID igual ao ID da organização no recurso do bucket de pacotes
C. Allow em s3:GetObject para o Principal da conta de gerenciamento da organização, com a expectativa de que o acesso seja herdado pelas contas membro da organização
D. Allow em s3:GetObject para o Principal "*" com a condição ForAnyValue:StringLike aws:PrincipalOrgPaths igual ao caminho da OU de produção da organização

Questão 8 · Domínio 5: Proteção de dados

Um hospital consome um SaaS de laudos por imagem hospedado na conta AWS do fornecedor, atrás de um Network Load Balancer, e hoje acessa o serviço pela internet. A nova exigência é que o tráfego nunca passe pela internet, que só o hospital possa iniciar conexões e que o fornecedor não tenha nenhuma rota para a rede do hospital. As duas VPCs usam o mesmo bloco 10.0.0.0/16. Qual solução atende a esses requisitos?

A. Criar uma conexão de VPC peering entre a VPC do hospital e a do fornecedor, com security groups que liberem só a porta do serviço a partir das sub-redes de aplicação do hospital
B. Compartilhar pelo AWS RAM um transit gateway do hospital com a conta do fornecedor e criar tabelas de rotas que permitam só o tráfego entre as sub-redes envolvidas
C. Pedir ao fornecedor um endpoint service do AWS PrivateLink com o NLB, liberando a conta do hospital, e criar no hospital um interface VPC endpoint nas sub-redes de aplicação
D. Manter o acesso pela internet com um NAT gateway e TLS 1.3, pedindo ao fornecedor uma lista de permissões com os IPs elásticos do NAT gateway do hospital

Questão 9 · Domínio 4: Gerenciamento de identidade e acesso

Uma empresa precisa dar acesso temporário a um provedor terceirizado, que tem conta AWS própria, para atividades de suporte em contas de produção. Os requisitos são: (1) nenhuma credencial de longa duração compartilhada; (2) identificar no CloudTrail as ações feitas pelo provedor; (3) revogar o acesso a qualquer momento; e (4) privilégio mínimo por função. Qual abordagem atende melhor a esses requisitos?

A. Role entre contas confiando na conta do provedor, com sts:ExternalId na trust policy e política de menor privilégio
B. Role entre contas confiando na conta do provedor, sem ExternalId, restrita pela condição aws:SourceIp aos IPs do provedor
C. Usuário do IAM Identity Center para cada técnico do provedor, com permission set de administrador nas contas
D. Usuário IAM com MFA para o provedor e chaves de acesso rotacionadas a cada 30 dias pelo Secrets Manager

Questão 10 · Domínio 5: Proteção de dados

Uma rede de streaming usa nos listeners HTTPS dos seus Application Load Balancers certificados públicos emitidos por uma CA comercial e importados no AWS Certificate Manager (ACM). No mês passado, um desses certificados expirou e o site ficou fora do ar por duas horas. A diretoria quer eliminar a troca manual de certificados nos domínios públicos com o menor esforço operacional contínuo. Os domínios estão no Amazon Route 53. Qual solução atende a esses requisitos?

A. Emitir certificados pela AWS Private CA com renovação gerenciada pelo ACM e associá-los aos listeners dos load balancers públicos
B. Ativar a renovação gerenciada nos certificados importados, informando ao ACM as credenciais da CA comercial para que ele renove e reimporte os certificados
C. Solicitar certificados públicos emitidos pelo ACM com validação por DNS no Route 53 e substituí-los nos listeners dos load balancers
D. Criar uma regra do EventBridge para o evento de certificado do ACM perto da expiração que notifique a equipe por SNS para reimportar a tempo

Gabarito comentado

1. D) Habilitar S3 Object Lock no bucket com retenção padrão em modo compliance de 10 anos e uma regra de S3 Lifecycle que mova os objetos para S3 Glacier Deep Archive após 30 dias
Imutável, raro acesso e mais barato: Object Lock compliance + Lifecycle para Glacier Deep Archive.

2. A) Usar uma chave simétrica gerenciada pelo cliente, com rotação automática e key policy que concede kms:CreateGrant e kms:Decrypt à conta de backup
Snapshot criptografado para outra conta: chave gerenciada pelo cliente com key policy liberando a conta de destino; aws/ebs não serve.

3. B) Usar uma chave gerenciada pelo cliente por ambiente, com key policy condicionada a aws:PrincipalTag e ao contexto de criptografia do ambiente
Isolar chaves por ambiente: uma chave por ambiente + key policy com aws:PrincipalTag e kms:EncryptionContext.

4. A) Executar uma restauração para um ponto no tempo às 14h00 em uma instância nova, isolar a instância comprometida por security group e tirar um snapshot dela, e apontar a aplicação para a nova
Recuperar RDS ao momento antes da adulteração e preservar evidência: point-in-time restore em instância nova; a original fica isolada para a perícia.

5. C) Permitir à role dos DBAs as ações de criptografia da chave com a condição kms:ViaService igual a rds.sa-east-1.amazonaws.com
Chave usável só através de um serviço: kms:ViaService com serviço.Região.amazonaws.com.

6. A) Trocar o Principal da trust policy da role de ec2.amazonaws.com para lambda.amazonaws.com com a ação sts:AssumeRole
Role cannot be assumed by Lambda: trust policy sem lambda.amazonaws.com. Erro de iam:PassRole: falta permissão para quem faz o deploy.

7. A) Allow em s3:GetObject para o Principal "*" com a condição StringEquals aws:PrincipalOrgID igual ao ID da organização no recurso do bucket de pacotes
Liberar recurso para toda a organização sem lista de contas: aws:PrincipalOrgID. Para OUs específicas: aws:PrincipalOrgPaths.

8. C) Pedir ao fornecedor um endpoint service do AWS PrivateLink com o NLB, liberando a conta do hospital, e criar no hospital um interface VPC endpoint nas sub-redes de aplicação
Consumir SaaS de parceiro sem internet, com CIDR sobreposto e sem expor sua rede: PrivateLink (endpoint service + interface endpoint).

9. A) Role entre contas confiando na conta do provedor, com sts:ExternalId na trust policy e política de menor privilégio
Terceiro acessando sua conta: role entre contas com ExternalId.

10. C) Solicitar certificados públicos emitidos pelo ACM com validação por DNS no Route 53 e substituí-los nos listeners dos load balancers
Certificado importado no ACM = renovação por sua conta. Certificado público emitido pelo ACM com validação DNS = renovação automática.

Pronto para o exame SCS-C03?

Treine com as 390 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →